RBAC权限管理系统

项目设计说明书

目录

1. 项目概述与需求综述 3

2. 功能需求与用例 5

3. 结构化分析与数据流设计 9

4. 数据库设计 17

5. API设计与交互约定 23

6. 结构化设计与代码组织 25

7. 典型处理过程 27

附录 A: 入站接口清单 29

附录 B: 数据流、用例、表与模块追踪摘要 35

1. 项目概述与需求综述

1.1. 项目要解决的问题

当同一组织拥有多个业务系统时，员工的功能权限容易分散在各系统中维护。人员兼岗、部门调整、角色变更和离岗关权又会使权限来源难以追溯。如果只记录“员工有某项权限”，就难以说明这项权限由哪个角色、哪个部门来源产生，也难以在撤销一个来源时保留其他合法来源。

本项目建设集中权限管理系统，统一维护业务系统的功能目录、角色及员工角色授权，并向业务系统提供有效权限查询和单项操作检查。权限变更通过外部OA审批后由权限中心可靠执行；组织人员变化引起的失效直接处理并留下审计。系统采用RBAC0，员工通过角色获得权限。

1.2. 一期范围与系统边界

范围项	当前设计
权限模型	角色配置是否授予系统进入权限与功能操作；允许同公司、同系统的多个有效来源取并集。
组织模型	公司—平级部门—岗位；员工通过任职关联岗位，可以兼岗。岗位本身不自动授予业务角色。
后台资格	后台账号、会话、管理员任命与管理范围独立维护；业务角色不授予后台管理资格。
审批边界	OA负责内部审批；权限中心提交固定申请、接收最终批准/驳回并执行。本期使用显式演示适配器。
人员来源	总管理员上传CSV/XLSX并确认映射、预检和冻结批次；一期不要求真实HR接口。
对外服务	业务系统后端使用受信员工标识查询权限；普通员工不直接登录权限中心后台。
不在一期内	角色继承、直接员工权限授予、显式拒绝、业务记录行过滤、通用单点登录及OA内部审批流程。

需求中HR可以作为资料来源描述；当前系统边界级数据流图只画实际直接交互的四类实体，HR文件通过总管理员上传，不虚构一条独立HR接口。

1.3. 参与者与职责

参与者	职责与边界
权限中心总管理员	维护系统与权限目录、全部公司及系统的角色和授权，管理后台账号、管理员范围、人员导入及全局审计。
权限管理员	每次请求选择一项有效任命，管理该项任命确定的公司、指定部门和系统集合；可有多项任命，但不能拼接范围。
OA系统	受理固定权限变更申请，提供可靠审批关联和可信最终结果；内部审批人员与流转不展开。
业务系统后端	自行认证员工，以绑定的服务身份查询功能权限，结合自身业务规则决定是否执行操作。

1.4. 贯穿系统的业务规则

1. 每个角色固定属于一个公司、一个业务系统，可限定部门；公司级共享角色只由总管理员维护。
2. 申请分配角色时，同时检查角色适用条件和明确的来源部门任职；公司级角色也不能随调岗自动转移来源。
3. 后台操作始终以当前一项任命覆盖全部目标；总管理员使用全局资格。前端显示范围不替代后端校验。
4. 角色配置、分配和一般撤销先形成草稿，再固定申请，经OA批准并成功执行后生效；提交和批准分别只是阶段结果。
5. 离岗关闭原部门来源直接持久失效，其他适用兼岗来源保留；全局停用员工还需联动任命和会话。恢复不复权。
6. 相同操作权限去重，编辑不自动推导查看；系统进入资格必须来自当前公司和当前系统。
7. 一份申请、本批导入或目录保存分别整体成功或整体回滚；审计失败也不能留下部分业务变更。
8. 旧申请、旧来源周期和旧授权关系不能在后续状态恢复后复活；新的授权必须重新申请。

2. 功能需求与用例

2.1. 全部用例与主要责任

用例	名称	DFD主责	主要结果
UC-01	维护业务系统与权限目录	P2	直接保存系统、目录和权限资料并审计
UC-02	创建角色并配置权限	P3、P5	经审批执行形成有效角色配置
UC-03	为员工分配角色	P3、P5	经审批执行新增明确来源授权
UC-04	撤销员工角色	P3、P4、P5	一般撤销经审批；离岗来源关闭直接生效
UC-05	查询员工有效权限	P6	进入资格、可见菜单及操作集合
UC-06	检查员工指定操作权限	P6	指定权限的布尔检查结果
UC-07	配置管理员及管理范围	P1	直接保存范围、任命与影响结果
UC-08	查询授权审计记录	P7	当前授权范围内的审计列表及详情
UC-09	管理员登录与退出	P1	会话、身份摘要或受限改密状态
UC-10	导入/同步员工组织信息	P4	冻结计划、整批提交及导入报告
UC-11	接收审批结果并执行权限变更	P5	审批结果和实际执行状态分别记录

2.2. UC-01：维护业务系统与权限目录

目标与前提：有效总管理员维护系统、导航目录和独立操作权限。系统新登记时，同事务建立唯一的SYSTEM_ACCESS权限；登记目录不等于给员工授权。

主处理：选择或登记系统，读取当前目录及版本，编制完整最终树和权限集合，设置功能的菜单可见绑定，预览影响后填写原因确认。后端校验编码、同系统归属、树无环、绑定合法性和并发版本，整体保存并追加审计。

异常与验收：重复编码、跨系统绑定、非法删除引用、陈旧版本或审计失败均拒绝或回滚。停用目录保留角色配置和历史，P6按当前目录状态过滤；恢复目录只可能恢复仍有效授权的目录能力。

2.3. UC-02：创建角色并配置权限

目标与前提：具备目标公司、部门和系统管理资格的管理员，为角色提出系统进入权限和功能操作配置。新角色先保存为未配置状态，角色元数据版本与有效配置版本分离。

主处理：确定固定归属，选择权限集合和原因，保存草稿并获取配置占用；查看差异与影响预览后提交固定申请。OA批准后，由UC-11复核并替换当前有效配置，保存配置历史和版本。

异常与验收：空配置、越范围、跨系统权限或重叠申请被拒绝；审批期间旧配置继续有效。驳回不改变当前配置，可复制为新草稿。角色配置更新后，P6从当前配置计算员工权限，不为每名员工复制一份权限集合。

2.4. UC-03：为员工分配角色

目标与前提：为有效员工新增角色关系。角色已生效，员工满足角色适用任职及来源部门任职，操作者的一项范围覆盖全部目标。

主处理：逐条明确员工、角色、来源公司/部门，读取配置版本、来源周期和关系基线，预览实际新增项并固定申请。审批执行成功后创建新的实际授予记录，保存执行时适用任职依据。

异常与验收：不使用员工与角色的隐式笛卡尔积。当前同源有效关系视为无变化，全部无变化不投OA；实际待办固定后不再静默裁剪。执行时资格、周期或配置版本不符合则整份失效，其他来源的合法授权保留。

2.5. UC-04：撤销员工角色与离岗关权

一般撤销：选择明确的实际授权关系和原因，形成草稿、预览、固定申请，经OA批准后结束该grant并推进关系版本。一般撤销不关闭整个来源，也不删除角色。

离岗关权：明确原部门来源，预览后直接关闭来源、结束相关有效授权，联动受影响固定申请失效并审计，不等待OA。即使原来源尚未有授权，也保留周期推进的持久依据，阻止迟到的旧授予。

异常与验收：旧撤销申请只能作用于原固定grant，不能撤销后续重新授予的新记录。同员工其他独立来源仍可贡献相同权限；关闭后恢复任职不自动复活旧grant。

2.6. UC-05：查询员工有效权限

业务系统后端提交可信员工统一标识和当前公司；系统归属从服务身份绑定核对。权限中心在同一当前主库快照内校验员工、任职、目录、角色和所有授权来源，返回SYSTEM_ACCESS结果、可见菜单及允许的操作集合。

员工不存在、停用、无当前公司任职或无进入资格时返回无进入资格和空菜单/操作；有进入资格而没有其他操作时可正常返回空功能集合。服务或数据完整性故障返回错误，不能伪装成正常空权限。待审批内容不参与计算。

2.7. UC-06：检查员工指定操作权限

调用方可独立提交员工、公司和指定权限编码，无需先调用UC-05。系统以相同有效授权规则判断SYSTEM_ACCESS或功能操作；检查功能操作时还需同时具备进入资格。未知、停用或未获授的权限返回false；认证、跨系统调用和服务故障分别返回调用错误，业务系统不能据故障放行。

2.8. UC-07：配置管理员及管理范围

有效总管理员确定公司、一个指定部门和系统集合，选择已有后台账号及符合该范围任职的候选人，预览影响后直接原子保存范围、任命和审计，不经OA。账号与范围通过独立任命关联，一人可以持有多项任命。

范围和任命各有自己的ID及版本。空管理员名单或空系统集合按明确输入保存，不扩大授权。实质失去目标覆盖的原范围申请须持久失效；有其他有效任命者仍可选择相应范围，失去全部资格者不能继续后台会话。

2.9. UC-08：查询授权审计记录

总管理员或权限管理员按时间、公司、系统、员工/角色、事件或申请筛选审计。P7按当前单项范围过滤列表、数量和详情，读取历史快照及关联申请的审批、执行状态；全局目录及任免审计只向总管理员开放。

审计只读、追加历史不改写，不提供重放授权入口。当前员工或角色更名后仍展示当时快照；不能安全分割的混合事件不向部分范围泄露。无匹配结果是正常空列表，查询故障是错误。

2.10. UC-09：管理员登录与退出

以后台登录名和密码验证账号及当前管理资格。账号关联员工时还须检查员工状态；业务角色不能替代后台任命。登录成功建立持久会话并返回身份摘要；首次或重置后的临时密码只得到改密/退出能力。

本人改密或总管理员重置密码时更新凭据版本，撤销全部旧会话；普通退出仅撤销当前会话。账号停用、员工停用或失去全部资格时旧会话立即不可用。任命或范围版本变化可能返回CONTEXT_CHANGED并要求重新选择当前范围，不能只依赖前端刷新或等待JWT到期。

2.11. UC-10：导入/同步员工组织信息

总管理员上传来源明确的CSV/XLSX，选择处理类型、工作表、字段及组织映射。系统解析后冻结完整输入和候选计划，展示问题、逐字段差异、明确状态动作和影响；确认时复核预检依赖并整批提交。

首次导入组织可以使用已提供的稳定编码，缺码时由后端按明确路径识别并生成映射；已有对象保持稳定身份。文件缺行不推断离职，人员更新需明确新增任职、结束任职、停用或恢复。导入不自动创建后台账号、任命管理员或授予业务角色。

同源批次重复提交返回原成功结果；预检后数据变化要求重做预检。第N条写入或最后审计失败都回滚全批；失败记录另存时不能覆盖并发已成功状态。恢复员工或重新任职不自动恢复旧资格和授权。

2.12. UC-11：接收审批结果并执行权限变更

OA服务提交最终批准或驳回。权限中心校验服务身份、可靠外部关联、固定申请版本和摘要，按事件、唯一最终结果与一次成功凭据分层防重。可信结果先可靠保存；批准随后由执行器自动复核并执行完整固定清单。

驳回只结束申请，不改业务授权。批准后发现原范围不再覆盖、角色或来源周期变动、目标不合法，整份标记失效；短暂存储失败回滚业务，保留批准依据并进入恢复。原申请人离任本身不单独阻断仍合法的固定申请，原范围已经持久失效的申请不能因范围后来恢复而复活。

3. 结构化分析与数据流设计

3.1. 顶层设计

顶层将集中权限管理系统作为一个整体，对接权限中心总管理员、权限管理员、OA系统和业务系统后端。总管理员提交登录、系统配置、授权和人员资料，接收身份、办理结果与审计数据；权限管理员提交登录及范围内管理资料，接收当前身份、管理范围和办理结果。系统向OA提交权限变更申请，接收审批关联及批准或驳回结果；业务系统提交员工、公司和权限查询条件，取得有效权限或操作校验结果。

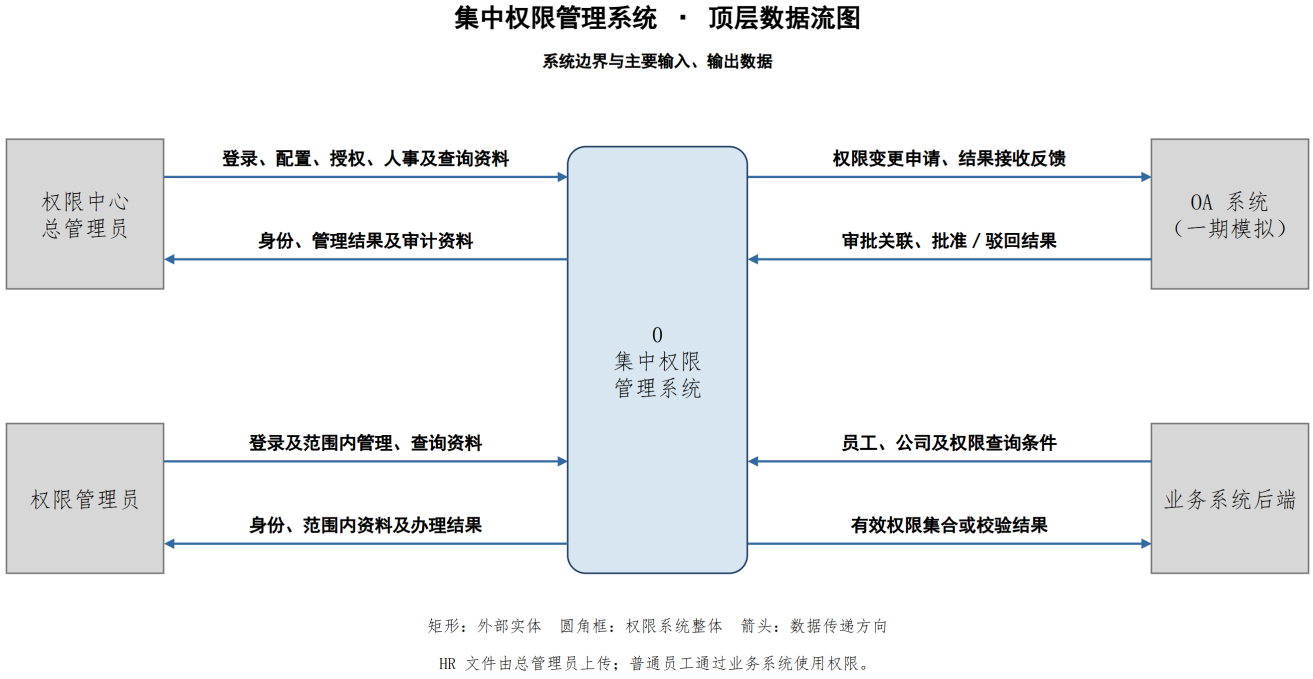


图 1. 系统边界级数据流图

第一层将系统划分为身份与范围、系统目录、变更申请、人员与授权来源、审批执行、权限计算和审计查询七个处理。各处理围绕同一组业务数据协作：申请阶段保存待办方案，执行阶段更新有效授权，查询阶段读取已经生效的数据。

3.2. P1：管理后台身份与管理范围

接收登录名、密码、账号和管理员任命资料，读取D1中的账号、会话、任命及管理范围，并结合D2的员工状态与有效任职判断后台资格。处理完成后保存账号、会话或范围变化，返回身份及管理结果；范围缩小导致原申请不再被覆盖时，将失效状态写入D6，并向D7保存审计。

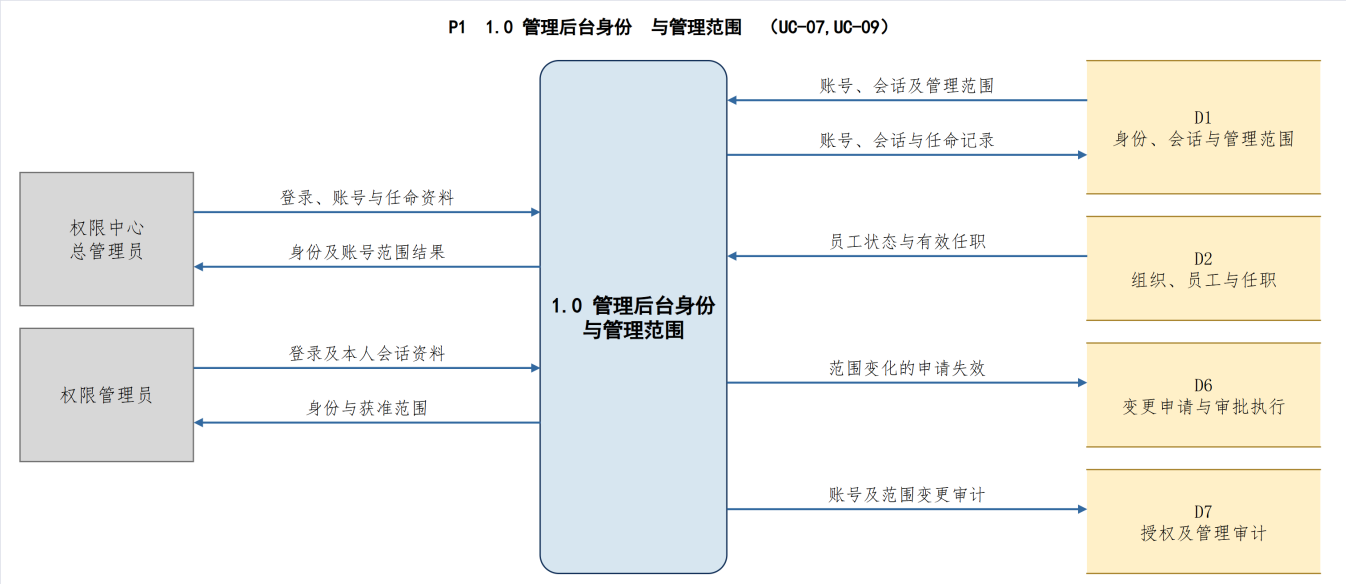


图 2. P1 身份与管理范围数据流

3.3. P2：维护系统与权限目录

接收总管理员提交的业务系统、菜单、功能和操作权限资料，读取D3的现有目录及相关角色、授权引用，检查目录归属、父子关系和权限绑定。保存后更新D3并记录D7维护审计，返回保存结果；后续权限查询使用更新后的目录。

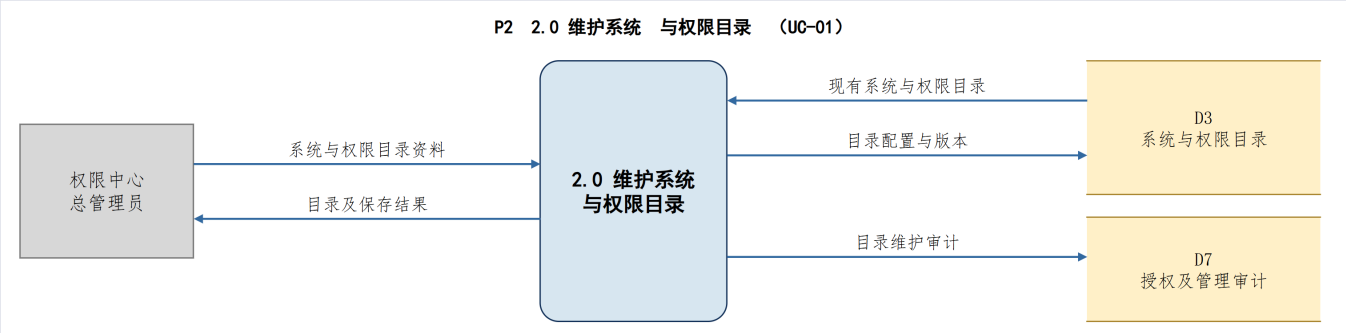


图 3. P2 系统与权限目录数据流

3.4. P3：编制权限变更申请

接收角色配置、角色分配或一般撤销资料，读取D4的角色配置、D5的员工来源与授权关系，以及D6中已有草稿。校验后生成草稿和影响预览；确认提交时固定目标清单、版本和原管理范围，保存到D6并建立OA投递待办，返回申请编号和办理状态。此时尚不改变员工的有效权限。

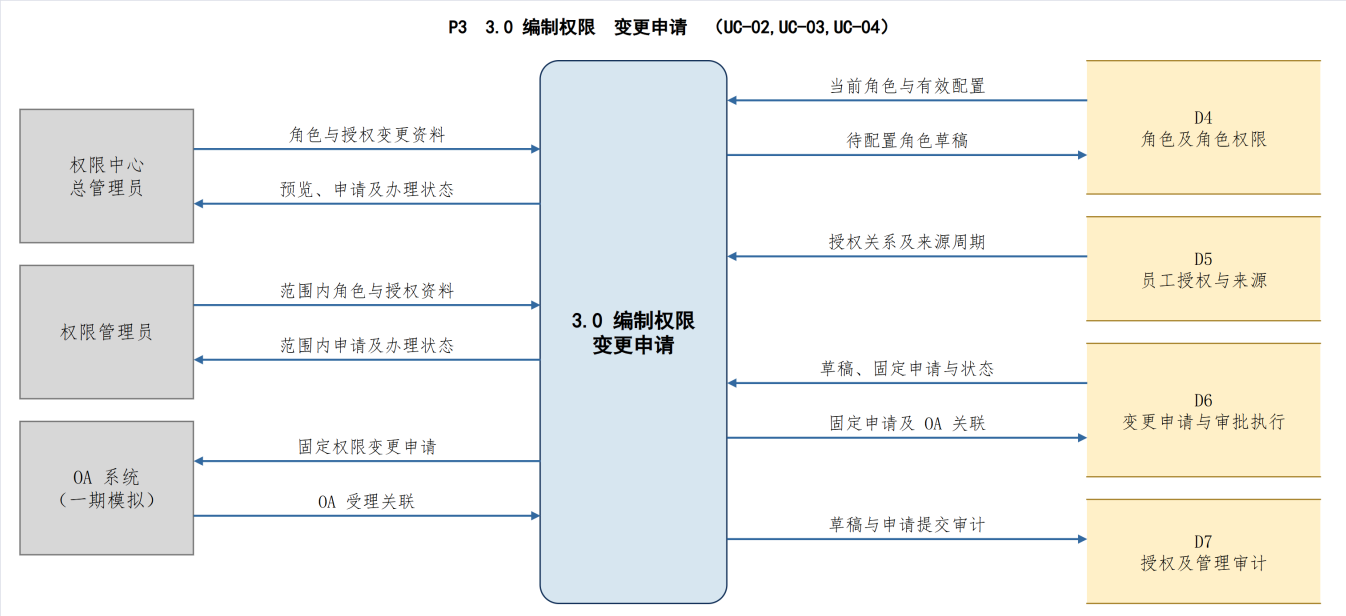


图 4. P3 权限变更申请数据流

3.5. P4：维护员工组织及授权来源

接收组织人员文件、字段映射、导入确认或离岗关权资料，读取D2中的组织任职及D5中的授权来源。导入预检和处理计划保存在D8，确认后整批更新组织任职；离岗、员工停用等变化同时结束受影响的来源和授权，并联动D1中的后台资格、D6中的未完成申请及D7中的审计。返回导入报告或关权结果。

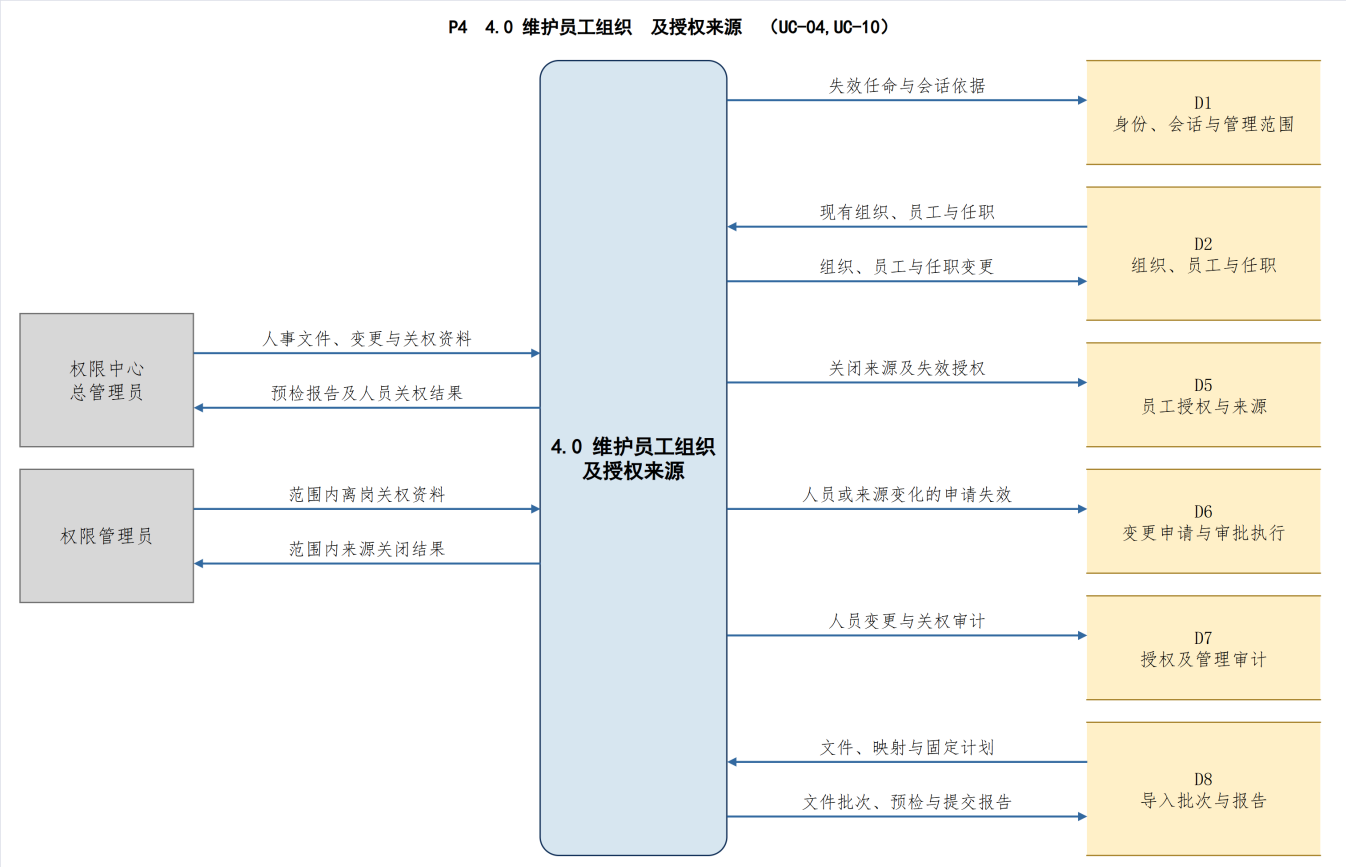


图 5. P4 员工组织与授权来源数据流

3.6. P5：处理审批结果并执行变更

接收OA最终审批结果，读取D6中的固定申请及审批关联。驳回时更新办理状态；批准后复核申请范围和当前角色、员工、来源状态，再调用对应业务模块执行整份方案。角色配置写入D4，实际授予或撤销写入D5，执行结果写入D6，审计写入D7。OA结果的接收和业务变更的成功分别保存，便于执行失败后恢复。

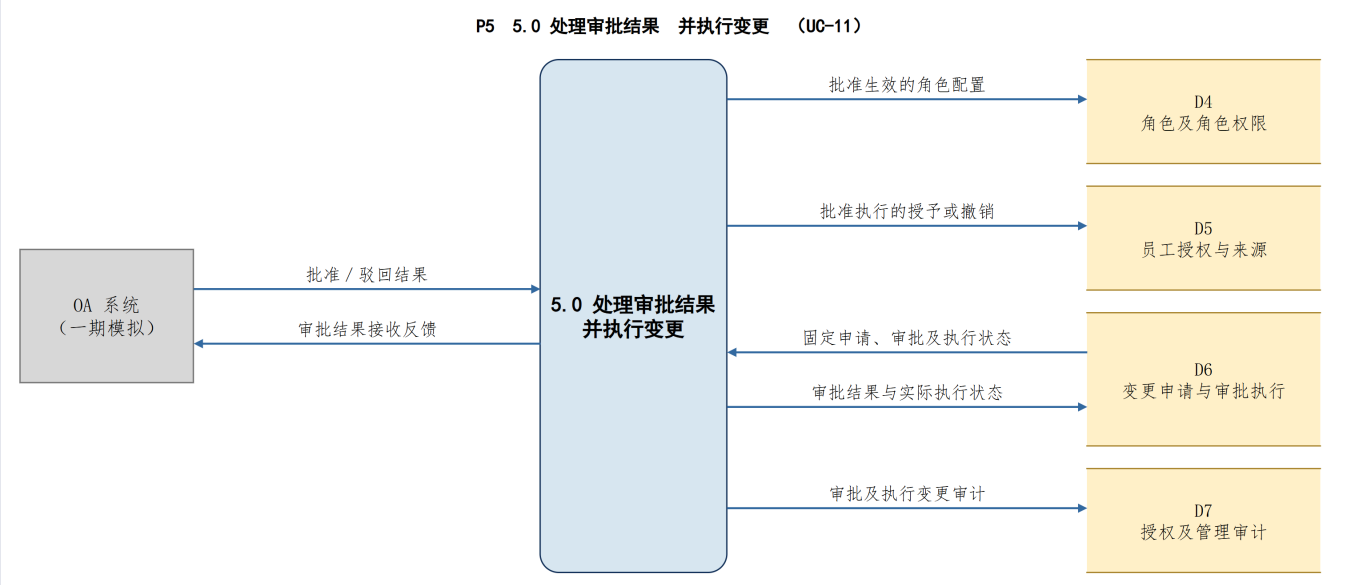


图 6. P5 审批结果与变更执行数据流

3.7. P6：计算与校验有效权限

接收可信业务系统提供的员工、公司和权限查询条件，读取D2的有效任职、D3的当前目录、D4的角色配置及D5的有效授权来源。对同公司、同系统的有效权限取并集，返回菜单、功能权限集合或指定操作的允许结果。该处理只读取已经生效的数据，不使用待审批方案，也不修改授权。

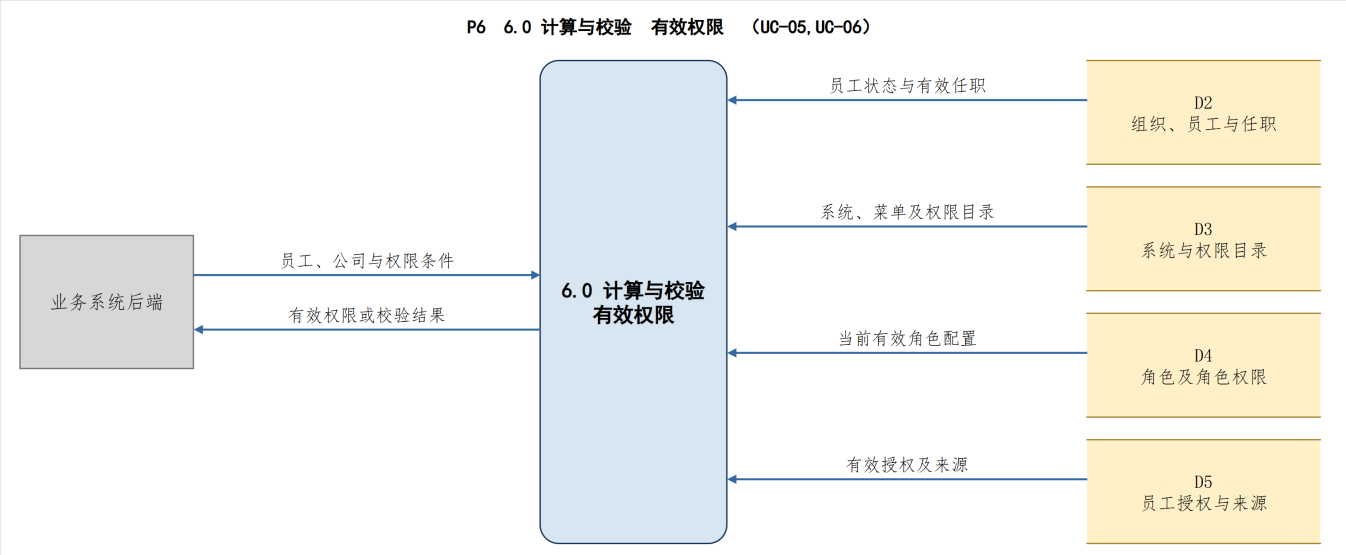


图 7. P6 有效权限计算与校验数据流

3.8. P7：查询审计记录

接收时间、员工、事件类型和分页等查询条件，根据当前管理员范围读取D7的审计列表和详情，并关联D6的申请、审批及执行状态。返回范围内的历史记录及统计结果，用于追溯一次操作由谁发起、影响了什么以及最终如何处理。

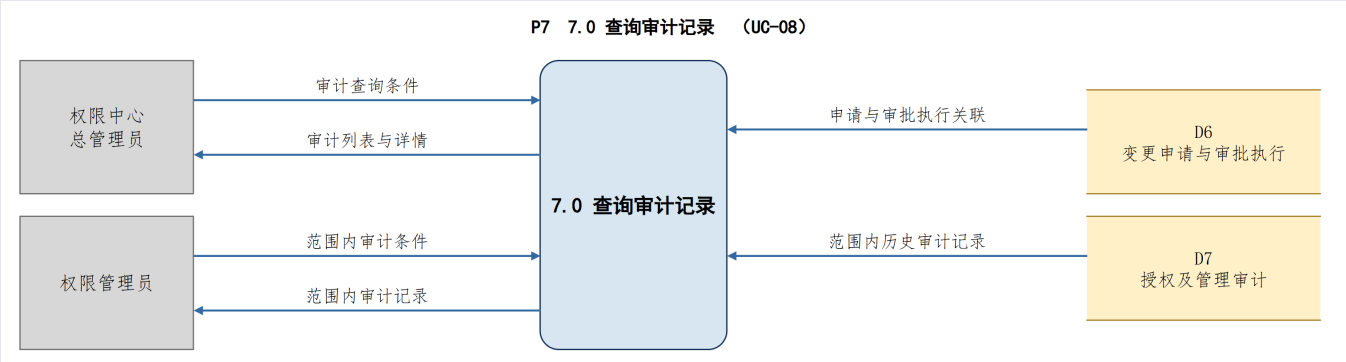


图 8. P7 审计记录查询数据流

4. 数据库设计

4.1. 总体设计

数据库采用MySQL关系模型，按组织与身份、目录与授权、申请与执行、导入与公共支撑划分数据。各表通过稳定ID关联，名称修改不改变对象身份；员工任职、管理员任命和业务角色授权分别保存，以表达不同的管理关系。

当前有效状态与历史记录分开：当前状态用于登录、范围判断和权限计算，历史记录用于追溯申请、授予、撤销和人员变化。申请内容与实际授权分开保存，使“提交申请”“审批通过”和“权限生效”能够独立表达。

4.2. 组织与后台身份

company、department和position分别保存公司、部门和岗位；employee保存员工身份，employment记录员工每次任职及结束情况。admin_account保存后台登录账号，admin_session保存可撤销的登录会话。management_scope定义公司和指定部门范围，scope_system保存可管理系统集合，admin_appointment记录账号在该范围中的管理员任命。

员工可以兼任多个岗位，管理员也可以拥有多项任命。任职说明员工在哪里工作，任命说明账号可以管理哪里，两者分别维护。

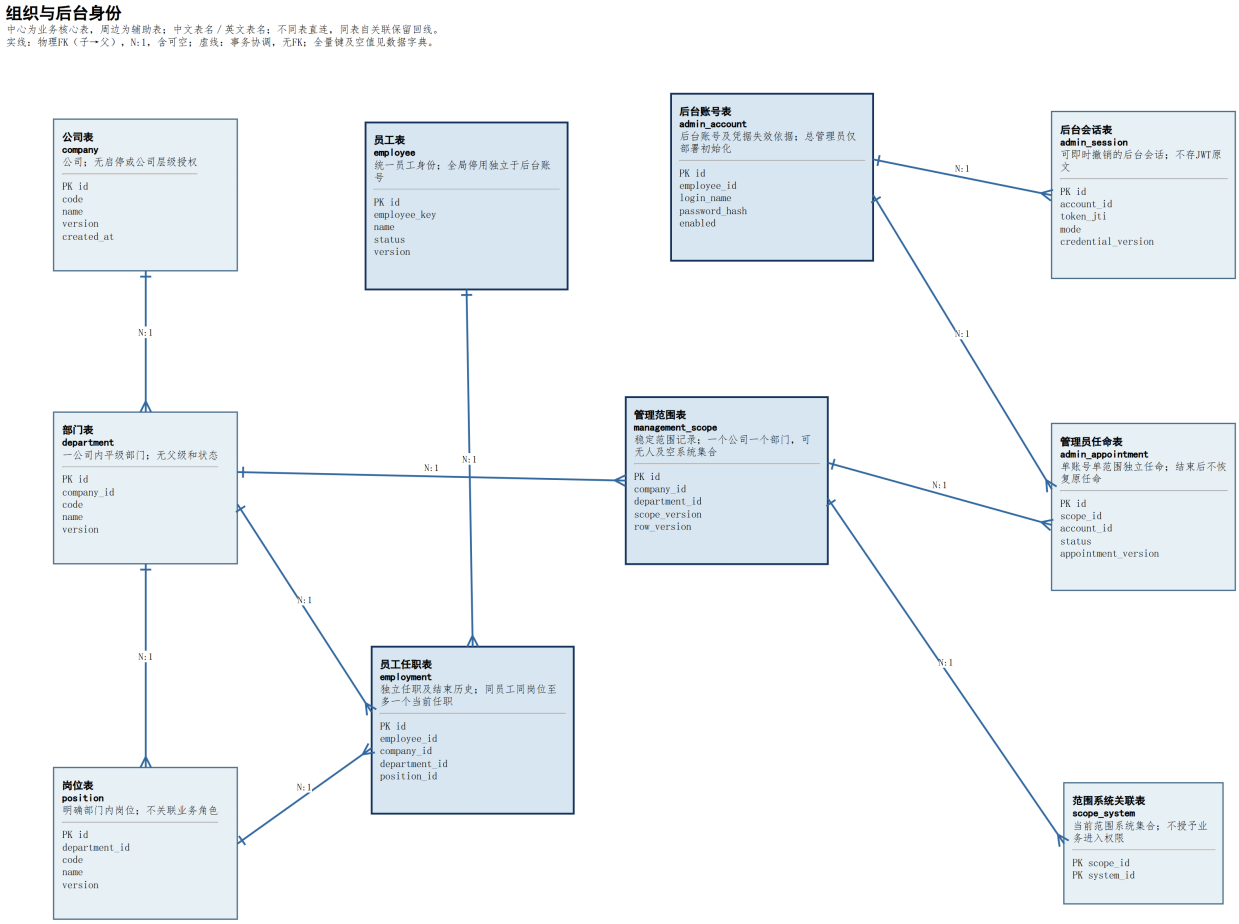


图 9. 组织与后台身份ER图

4.3. 目录、角色与授权来源

business_system保存业务系统，directory_node保存菜单和功能目录，permission保存可授权的操作。business_role定义角色，role_permission保存角色当前权限集合，role_configuration_history保留配置变更历史。

authorization_source记录员工在某公司、来源部门和系统下的授权来源；grant_baseline保存该来源与角色的关系，role_grant记录每次实际授予及结束，grant_employment_evidence保存授予时的任职依据。这样可以撤销一个来源，同时保留员工从其他有效来源取得的权限。

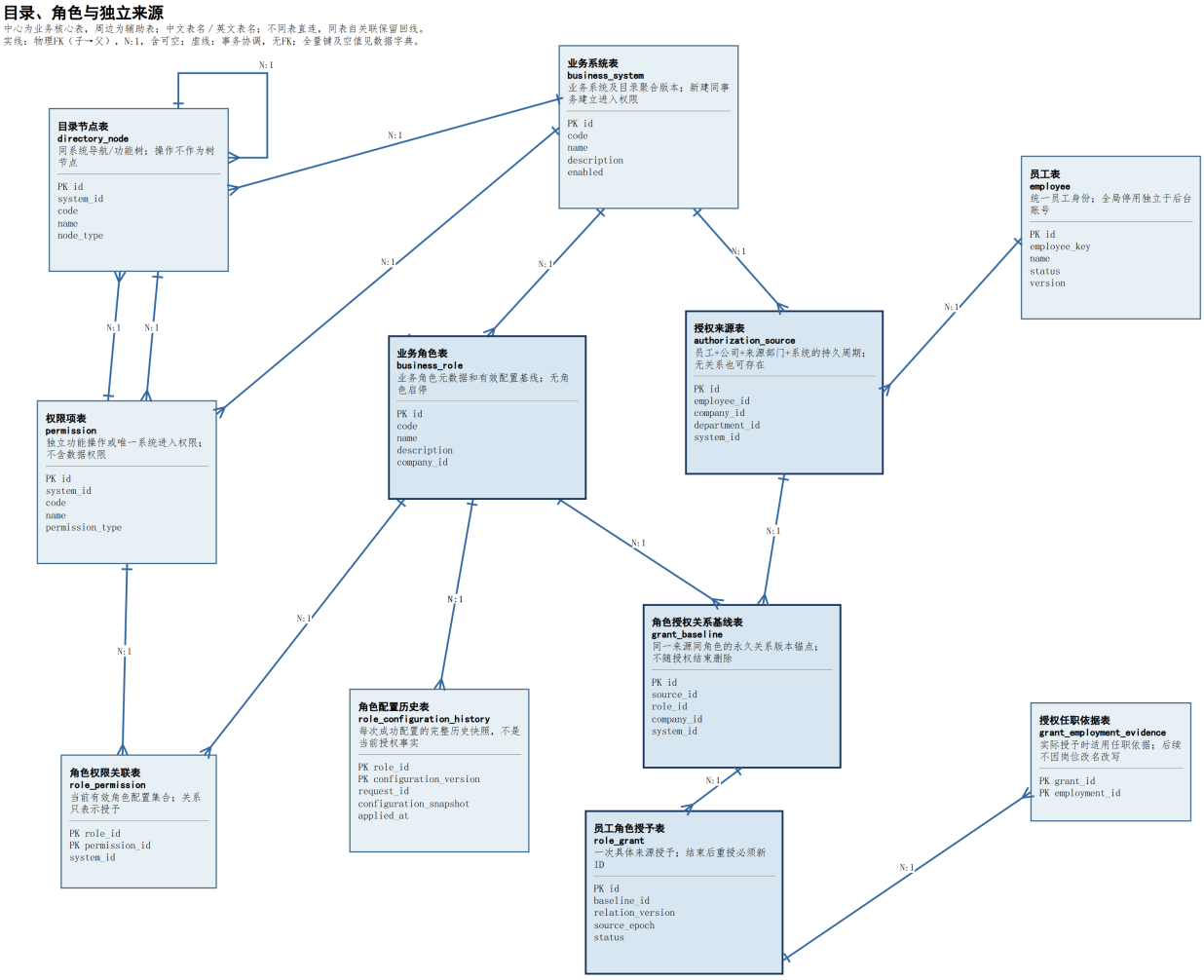


图 10. 目录、角色与授权来源ER图

4.4. 申请、审批与执行

change_request保存申请内容和办理状态，change_target保存申请涉及的目标；role_change_claim和relation_change_claim防止同一角色或授权关系同时办理冲突变更。oa_outbox记录待投递申请，oa_link保存外部审批关联，oa_callback_event记录收到的事件，oa_final_result保存最终审批结论。

execution_success记录一次申请已经成功执行，execution_attempt保存执行尝试。audit_event保存操作审计，audit_subject关联涉及的员工、角色等对象，支持按业务对象追溯。

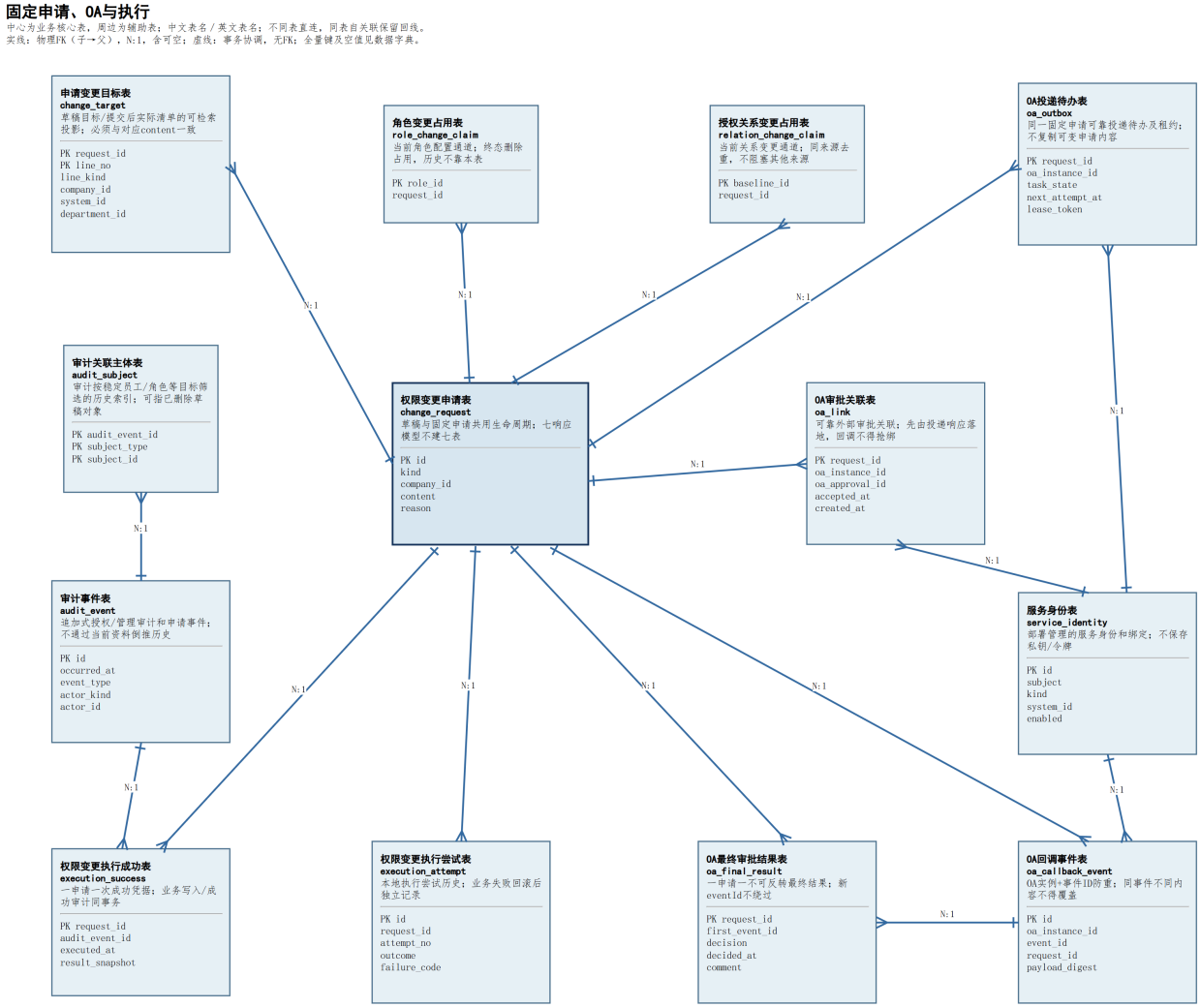


图 11. 申请、审批与执行ER图

4.5. 导入、预览与公共支撑

import_file记录上传文件，import_batch保存导入批次及结果，import_plan_row保存确认后的处理动作，import_issue记录预检问题。organization_mapping和employee_source_identity分别保存外部组织、员工与系统内部对象的对应关系。

impact_preview和preview_item保存确认前的影响预览；http_idempotency保存重复请求的办理结果；mutation_guard为需要协调的写事务提供统一锁定位置。这些表支持导入确认、重复提交和并发写入处理。

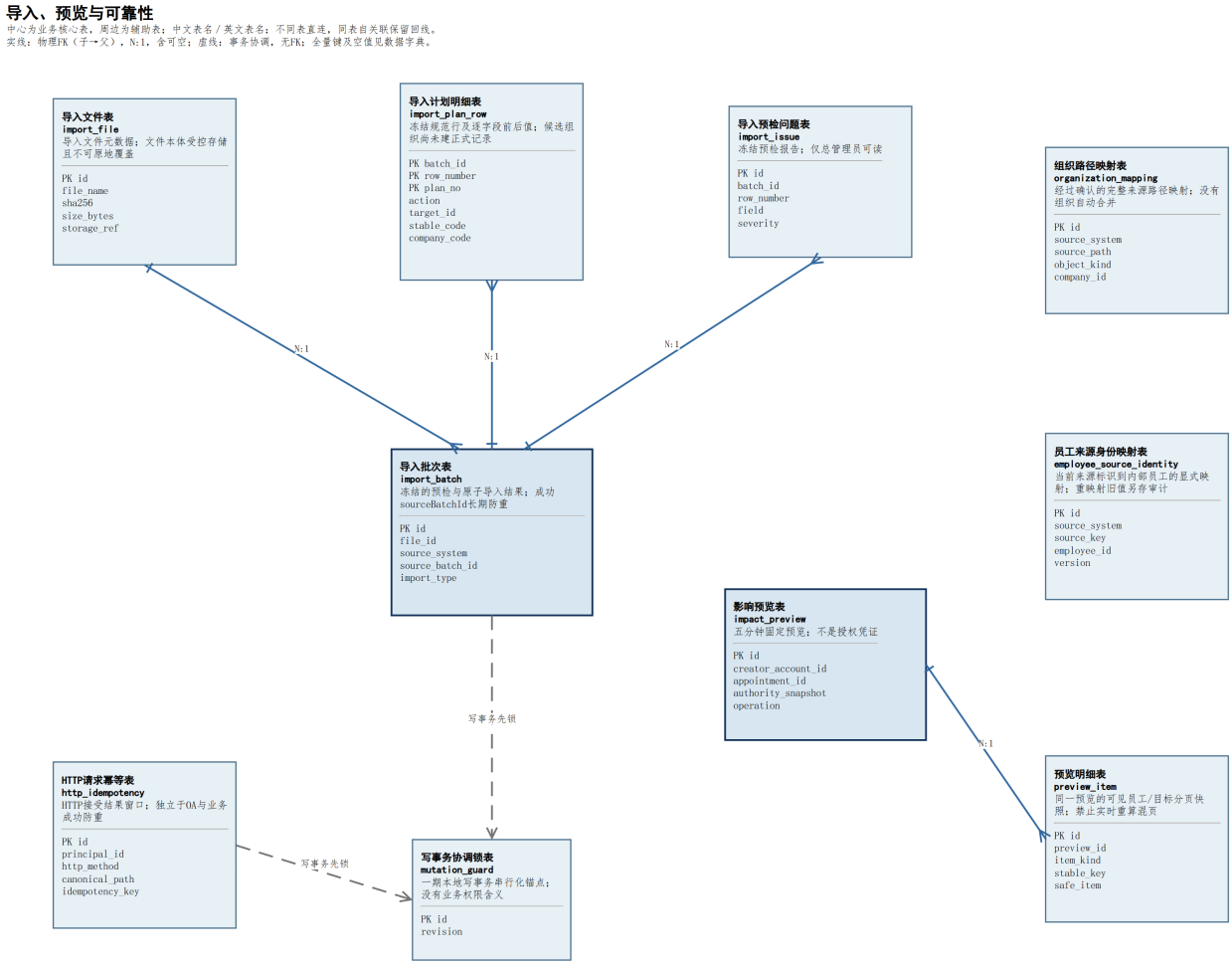


图 12. 导入、预览与公共支撑ER图

4.6. 原子保存的实现

原子保存由公共基座中的CommandBoundary统一执行。它使用Spring的TransactionTemplate开启数据库事务，业务模块通过同一个WriteContext完成所有写入。WriteContext绑定当前事务和数据库连接，内部写入方法检查该上下文，不能把一项批量操作拆成逐条独立提交。

以管理员范围变更为例，一次操作包含以下步骤：

1. 进入写事务，使用SELECT revision FROM mutation_guard WHERE id=1 FOR UPDATE锁住协调记录，随后重新读取并校验当前管理员资格、范围版本和全部目标。
2. 在同一事务中更新management_scope和scope_system，结束或新增相关admin_appointment；账号失去全部后台资格时撤销其会话。
3. 检查原范围关联的申请，将不再被覆盖的申请标记失效，并释放对应占用、停止后续投递。
4. 调用AuditAppender写入audit_event和audit_subject；使用HTTP幂等的操作同时保存本次办理结果。
5. 所有步骤成功后由事务管理器统一提交并释放锁。任何校验、数据库或审计写入失败，都会抛出异常或将事务标记为回滚，前面的范围、任命、会话及申请修改一起撤销。

协调锁解决并发写入之间的先后关系；同一数据库事务保证这一组修改全部成功或全部回滚。对于OA交互，网络投递放在事务外，最终审批结果先可靠保存；后续授权执行另开事务，将授权修改、执行成功记录、申请状态和审计一并提交。执行失败不会丢失已接收的审批结果，也不会留下部分授权。

5. API设计与交互约定

5.1. 资源、入口与认证

本节说明谁可以调用哪些接口，以及系统如何识别调用者。系统将接口分成三类，统一放在/api/v1下：

接口入口	调用者	主要用途
/admin	总管理员、权限管理员	登录，以及办理账号、角色、授权申请和管理范围等操作
/integration	业务系统后端	查询员工的有效权限，检查员工能否执行指定操作
/oa	OA系统	提交与固定申请对应的最终审批结果

三类调用分别使用AdminJwt、BusinessJwt和OaJwt作为身份凭证，不能互相替代。管理员先通过登录接口取得凭证；业务系统和OA使用各自的服务身份。业务系统的服务凭证保存在后端，不交给普通员工使用的浏览器。

身份验证通过后，还要判断本次操作是否在允许范围内。例如，一个权限管理员同时管理A公司和B公司，每次操作都要选择其中一项有效任命。后端根据这项任命读取公司、部门和系统范围，不能把两项任命拼成一个更大的范围。

前端通过请求头携带任命编号及版本，后端再检查当前账号、会话、任命和范围。账号停用或管理资格取消后，即使原凭证尚未过期，也不能继续越权访问；只发生范围版本变化且仍有有效任命时，应重新读取当前任命信息。

5.2. 版本、预览和幂等

本节说明系统如何防止旧数据、重复点击和网络重试造成错误变更，主要采用版本检查、影响预览和幂等处理。

- **版本检查：防止用旧数据覆盖新数据。** 例如，管理员打开角色配置页面后，其他人已经修改了该角色。提交时，后端比较页面携带的版本和当前版本，发现不一致就提示冲突，要求重新读取。角色配置、申请草稿和授权来源分别记录自己的版本，用于检查对应数据是否发生变化。
- **影响预览：先看清楚本次操作会改变什么。** 例如，分配角色前先展示将新增的授权及受影响员工，再由管理员确认。预览有效期为5分钟；确认提交时还要重新检查数据和管理范围，避免预览后发生的变化被忽略。
- **幂等处理：同一次提交重复发送，不能重复办理。** 例如，管理员点击提交后网络超时，前端重发相同请求。需要防重的写接口使用Idempotency-Key标识同一次操作；在身份和范围检查通过后，相同请求返回已有办理结果，不再重复执行。新的操作应使用新的键，不能把同一键用于不同内容。

OA投递、审批回调和业务执行也分别防重：投递始终使用同一个固定申请编号，回调根据OA实例和事件编号识别重复消息，执行前检查该申请是否已经成功。这样，重复收到批准结果或恢复任务再次扫描时，都不会重复授予权限。X-Request-Id用于定位一次调用及其日志，不能代替上述防重标识。

5.3. 响应与异常

本节说明调用结束后系统返回什么，以及调用方如何理解结果。接口使用HTTP状态码区分正常结果、业务冲突和调用失败：

状态码	调用方应如何理解
200 / 201 / 204	按具体接口表示查询或处理成功、创建成功，或操作完成且没有响应正文
202	申请已受理，或OA结果已可靠接收；仍需查看后续办理状态，不能据此判断权限已经生效
401 / 403	身份无效或已被撤销，或者当前身份无权执行这项操作
404	对象不存在，或当前调用者不可查看该对象；不通过错误信息泄露范围外的数据
409	当前版本、办理占用或预览发生冲突，需要重新读取数据或处理冲突后再提交
422	参数或业务条件不符合要求，例如缺少必填信息或目标不满足办理条件
429 / 503	请求过于频繁，或服务、数据库暂时不可用；根据返回提示决定何时重试

调用失败时，接口用统一的Problem错误结构返回错误类型、说明和requestId，便于前端展示及后端排查。涉及身份和敏感资料的响应不缓存。

“员工没有权限”与“权限查询失败”需要明确区分。前者是正常业务结果，可以返回false或空权限集合；后者可能由身份认证失败、数据库故障等引起，必须返回相应错误。业务系统收到调用失败时，应按失败处理，不能把它当作查询成功后得到的“无权限”。

完整接口列表见附录A；具体字段、请求示例及响应结构以OpenAPI1.2.0契约为准。

6. 结构化设计与代码组织

6.1. 设计方法与模块划分

系统采用结构化分析与设计：从输入、处理、存储和输出确定P1～P7，再按业务职责分解模块，明确模块接口和调用关系。部署采用模块化单体，各业务模块共享一个Spring Boot应用和MySQL数据库，便于在本地事务中完成跨表变更。

实现分为公共基座和四组业务模块。公共基座先提供工程配置、数据库接入、事务边界、审计追加和HTTP幂等能力；A～D在这些公共能力之上维护各自业务。划分依据是数据和规则的归属，同类数据的更新逻辑集中在对应模块中，其他模块通过明确的内部接口调用。

模块组	主要代码包	业务职责
公共基座	core及应用配置、数据库迁移	统一事务、WriteContext、审计追加、幂等和公共错误处理，为业务模块提供一致的写入和读取边界
A：后台身份与管理范围	identity、scope及lifecycle中的资格联动	账号、密码、会话、管理员任命和范围；组织状态或范围改变时协调后台资格与未完成申请失效，对应P1
B：目录、角色与有效权限	catalog、role、query中的权限与预览	维护系统目录和角色配置，提供角色配置应用器；计算有效权限、校验操作和生成影响预览，对应P2、P6并支撑P3、P5
C：申请、审批执行与审计查询	change、oa、execution及审计查询	编制和固定申请，可靠投递及接收OA结果，组织整份执行和失败恢复，提供审计列表与详情，对应P3、P5、P7
D：组织人员、授权来源与导入	people、grant、imports及lifecycle中的人员处理	维护组织任职、授权来源和实际授予；处理离岗关权、文件预检及整批导入，对应P4并向P3、P5提供授权数据和写入接口

跨模块业务由应用服务统一组织。例如批准角色分配时，C的执行服务负责整份申请，调用D的授权写入接口；批准角色配置时调用B的配置应用器。D的来源关闭模块返回受影响的来源和关系，再由生命周期处理调用会话、任命及申请失效接口。底层模块维护本域数据，不反向调用上层流程，公共基座也不依赖具体业务模块。

6.2. 分层设计

各业务按接口适配、应用处理、业务规则与数据访问划分职责。处理层接收清晰的输入数据，调用下层能力完成加工，再返回结果；跨模块调用共享事务上下文，避免重复开启事务。

层次	代码位置或代表对象	职责与调用方式
接口适配层	web中的Controller、DTO及安全入口	接收HTTP参数和认证信息，转换为业务输入；调用应用服务，将结果转换为响应或Problem，不直接更新数据库
应用处理层	IdentityService、SubmissionService、ExecutionService等	组织完整业务过程，选择读写事务，完成资格复核、目标校验和模块协调；决定哪些修改必须一起提交
业务规则与内部接口	ScopeCoveragePolicy、DraftPlanner、RoleConfigurationApplier、GrantApplier等	判断范围、计算实际变更、应用本域更新；只接收明确输入及受控上下文，不处理HTTP细节
数据与外部适配层	Repository、Store、SQL/JPA、文件解析器、OaSubmissionPort实现	读取或保存业务数据，解析导入文件，与OA交换数据；将持久化或外部结果返回上层

读操作使用ReadBoundary，在同一数据库快照中取得当前身份、范围和查询结果；写操作使用CommandBoundary，使业务写入与审计共同提交。前端frontend/src负责页面和请求封装，数据库迁移位于backend/src/main/resources/db/migration；后端业务代码位于backend/src/main/java/com/adgn/backend下的上述功能包。

7. 典型处理过程

7.1. 管理员登录与范围访问

该过程对应P1，将登录输入加工为可校验的后台会话和管理身份，数据涉及D1身份范围、D2员工任职和D7审计。

处理环节	模块及主要实现	输入、处理与输出
接收登录资料	接口层IdentityController	接收登录名、密码和请求标识，交给IdentityService
验证账号与当前资格	身份模块IdentityService、CurrentIdentityReader	读取账号、员工和任命，验证密码；进入写事务后再次核对凭据和当前资格
保存登录结果	公共事务、IdentityRepository、AuditAppender	同事务保存admin_session和登录审计，返回会话凭证及身份摘要；审计失败则会话一起回滚
处理后续范围访问	身份与范围模块ManagementContextResolver、ScopeCoveragePolicy	根据当前会话和所选任命确认范围，再交给具体业务模块；已撤销会话或失效资格不能继续使用

接口层负责输入输出，身份模块负责资格转换，范围模块负责覆盖判断，公共基座负责一致提交，各处理职责独立。

7.2. 角色分配、审批执行与权限查询

该过程由P3编制申请、P5执行审批结果、P6读取有效权限组成。三个处理通过固定申请和实际授权数据衔接，提交申请与权限生效分别由不同模块负责。

处理环节	模块及主要实现	输入、处理与输出
形成申请	申请模块ChangeDraftService、SubmissionService	接收员工、角色和来源部门，读取任职、角色与已有关系，生成预览；确认后将固定申请和投递待办写入D6
取得审批结果	OA模块OaDeliveryService、OaResultService	向OA投递固定申请，保存审批关联；校验收到的结果并可靠保存批准或驳回结论
执行整份方案	执行模块ExecutionService调用GrantApplier	读取批准申请并复核当前范围、任职和来源；同事务写入D5实际授权、D6执行成功及状态、D7审计，失败则全部回滚
输出有效权限	权限查询模块AuthorizationService	读取D2任职、D3目录、D4角色配置和D5有效来源，返回同公司、同系统的权限并集或指定操作结果

执行模块负责整个申请的复核和提交，授权模块负责本域写入，查询模块只读取有效结果。重复审批或恢复扫描通过已有成功记录避免重复执行；若来源已经关闭，则申请不能再次恢复该来源的权限。

附录 A：入站接口清单

本附录从OpenAPI1.2.0提取67个入站操作，保留方法、完整路径、操作名、访问类别、成功码与必需业务头。认证头按各入口安全方案提供；路径/请求体中具体版本字段和完整输入输出Schema以契约定义为准。带“范围”的操作按当前单项任命处理，表中多种成功码表示不同业务结果，不代表都修改了授权。

A.1. 会话

方法与路径	操作	认证、响应及必需业务头
POST /api/v1/admin/sessions	管理员登录（login）	认证：匿名/按操作约定；成功：201；访问：公开；必需头：依认证入口；无额外业务必需头
GET /api/v1/admin/sessions/current	读取当前正常会话（currentSession）	认证：AdminJwt；成功：200；访问：管理员；必需头：依认证入口；无额外业务必需头
DELETE /api/v1/admin/sessions/current	退出当前会话（logout）	认证：AdminJwt；失效/过期退出统一204；成功：204；访问：管理员；必需头：依认证入口；无额外业务必需头
PUT /api/v1/admin/password	修改本人密码并撤销全部会话（changeOwnPassword）	认证：AdminJwt；成功：204；访问：管理员；必需头：依认证入口；无额外业务必需头
GET /api/v1/admin/my-appointments	分页读取当前有效任命（myAppointments）	认证：AdminJwt；成功：200；访问：管理员；必需头：依认证入口；无额外业务必需头

A.2. 账号

方法与路径	操作	认证、响应及必需业务头
GET /api/v1/admin/accounts	后台账号列表（listAccounts）	认证：AdminJwt；成功：200；访问：总管理员；必需头：依认证入口；无额外业务必需头
POST /api/v1/admin/accounts	创建权限管理员后台账号（createAccount）	认证：AdminJwt；成功：201；访问：总管理员；必需头：Idempotency-Key
GET /api/v1/admin/accounts/{accountId}	读取后台账号（getAccount）	认证：AdminJwt；成功：200；访问：总管理员；必需头：依认证入口；无额外业务必需头
PUT /api/v1/admin/accounts/{accountId}/state	启停后台账号（setAccountState）	认证：AdminJwt；成功：200；访问：总管理员；必需头：Idempotency-Key
PUT /api/v1/admin/accounts/{accountId}/password	重置权限管理员临时密码（resetAccountPassword）	认证：AdminJwt；成功：200；访问：总管理员；必需头：Idempotency-Key

A.3. 目录

方法与路径	操作	认证、响应及必需业务头
GET /api/v1/admin/systems	可见业务系统列表（listSystems）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
POST /api/v1/admin/systems	登记系统及唯一进入权限（createSystem）	认证：AdminJwt；成功：201；访问：总管理员；必需头：Idempotency-Key
GET /api/v1/admin/systems/{systemId}	系统详情（getSystem）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
PUT /api/v1/admin/systems/{systemId}	保存系统资料及启停状态（updateSystem）	认证：AdminJwt；成功：200；访问：总管理员；必需头：Idempotency-Key
POST /api/v1/admin/systems/{systemId}/state-previews	系统资料与状态变更预览（systemStatePreview）	认证：AdminJwt；成功：200；访问：总管理员；必需头：依认证入口；无额外业务必需头
GET /api/v1/admin/systems/{systemId}/directory-nodes	分页读取目录节点（listDirectoryNodes）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
GET /api/v1/admin/systems/{systemId}/permissions	分页读取权限目录（listPermissions）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
POST /api/v1/admin/systems/{systemId}/catalog-previews	原子目录变更预览（catalogPreview）	认证：AdminJwt；成功：200；访问：总管理员；必需头：依认证入口；无额外业务必需头
POST /api/v1/admin/systems/{systemId}/catalog-changes	原子保存目录变更（saveCatalog）	认证：AdminJwt；成功：200；访问：总管理员；必需头：Idempotency-Key

A.4. 角色

方法与路径	操作	认证、响应及必需业务头
GET /api/v1/admin/roles	分页读取可见角色（listRoles）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
POST /api/v1/admin/roles	创建角色与初始配置草稿（createRole）	认证：AdminJwt；成功：201；访问：范围；必需头：Idempotency-Key
GET /api/v1/admin/roles/{roleId}	读取角色有效配置（getRole）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
PUT /api/v1/admin/roles/{roleId}/metadata	修改角色名称与说明（updateRoleMetadata）	认证：AdminJwt；成功：200；访问：范围；必需头：Idempotency-Key

A.5. 员工

方法与路径	操作	认证、响应及必需业务头
GET /api/v1/admin/employees	分页读取可管理员工（listEmployees）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
GET /api/v1/admin/employees/{employeeId}	员工安全详情（getEmployee）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
GET /api/v1/admin/employees/{employeeId}/employments	分页读取可见任职（listEmployments）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
GET /api/v1/admin/grants	分页读取独立来源授权关系（listGrants）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
POST /api/v1/admin/grant-baselines	读取分配所需关系与来源基线（grantBaselines）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头

A.6. 申请

方法与路径	操作	认证、响应及必需业务头
GET /api/v1/admin/change-requests	分页读取可见申请（listChangeRequests）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
POST /api/v1/admin/change-requests	保存配置/分配/撤销草稿（createChangeDraft）	认证：AdminJwt；成功：201；访问：范围；必需头：Idempotency-Key
GET /api/v1/admin/change-requests/{requestId}	固定申请详情（getChangeRequest）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
PUT /api/v1/admin/change-requests/{requestId}	协作编辑未提交草稿（updateChangeDraft）	认证：AdminJwt；成功：200；访问：范围；必需头：Idempotency-Key
DELETE /api/v1/admin/change-requests/{requestId}	删除未提交草稿（deleteChangeDraft）	认证：AdminJwt；成功：204；访问：范围；必需头：Idempotency-Key
POST /api/v1/admin/change-requests/{requestId}/previews	预览差异与员工影响（changePreview）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
POST /api/v1/admin/change-requests/{requestId}/submissions	冻结并提交 OA 申请（submitChange）	认证：AdminJwt；成功：202/200；访问：范围；必需头：Idempotency-Key
POST /api/v1/admin/change-requests/{requestId}/delivery-retries	重试原固定申请投递（retryOaDelivery）	认证：AdminJwt；成功：202；访问：范围；必需头：Idempotency-Key
GET /api/v1/admin/change-requests/{requestId}/events	分页读取申请事件（listChangeEvents）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头

方法与路径	操作	认证、响应及必需业务头
GET /api/v1/admin/previews/{previewId}/employees	分页读取影响员工（listPreviewEmployees）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
GET /api/v1/admin/previews/{previewId}/targets	分页读取预览目标影响（listPreviewTargets）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头

A.7. 来源

方法与路径	操作	认证、响应及必需业务头
POST /api/v1/admin/source-baselines	读取来源周期基线（sourceBaselines）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
POST /api/v1/admin/source-closure-previews	预览关闭原部门权限（sourceClosePreview）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
POST /api/v1/admin/source-closures	直接关闭原部门授权来源（closeSource）	认证：AdminJwt；成功：200；访问：范围；必需头：Idempotency-Key

A.8. 组织导入

方法与路径	操作	认证、响应及必需业务头
GET /api/v1/admin/companies	分页读取公司（listCompanies）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
GET /api/v1/admin/departments	分页读取平级部门（listDepartments）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
GET /api/v1/admin/positions	分页读取岗位（listPositions）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
POST /api/v1/admin/employees/{employeeId}/state-previews	预览员工全局停用/恢复（employeeStatePreview）	认证：AdminJwt；成功：200；访问：总管理员；必需头：依认证入口；无额外业务必需头
PUT /api/v1/admin/employees/{employeeId}/state	员工全局停用或恢复（setEmployeeState）	认证：AdminJwt；成功：200；访问：总管理员；必需头：Idempotency-Key
POST /api/v1/admin/import-files	上传导入文件（uploadImportFile）	认证：AdminJwt；成功：201；访问：总管理员；必需头：Idempotency-Key
GET /api/v1/admin/import-files/{fileId}	读取暂存文件元信息（getImportFile）	认证：AdminJwt；成功：200；访问：总管理员；必需头：依认证入口；无额外业务必需头

方法与路径	操作	认证、响应及必需业务头
POST /api/v1/admin/import-batches	建立冻结预检批次（precheckImport）	认证：AdminJwt；成功：201；访问：总管理员；必需头：Idempotency-Key
GET /api/v1/admin/import-batches	分页读取导入批次（listImportBatches）	认证：AdminJwt；成功：200；访问：总管理员；必需头：依认证入口；无额外业务必需头
GET /api/v1/admin/import-batches/{batchId}	导入批次及执行报告（getImportBatch）	认证：AdminJwt；成功：200；访问：总管理员；必需头：依认证入口；无额外业务必需头
GET /api/v1/admin/import-batches/{batchId}/issues	分页读取逐行预检问题（listImportIssues）	认证：AdminJwt；成功：200；访问：总管理员；必需头：依认证入口；无额外业务必需头
POST /api/v1/admin/import-batches/{batchId}/commits	原子执行冻结导入批次（commitImport）	认证：AdminJwt；成功：200；访问：总管理员；必需头：Idempotency-Key
GET /api/v1/admin/import-batches/{batchId}/changes	分页读取冻结导入计划明细（listImportPlanChanges）	认证：AdminJwt；成功：200；访问：总管理员；必需头：依认证入口；无额外业务必需头

A.9. 范围

方法与路径	操作	认证、响应及必需业务头
GET /api/v1/admin/management-scopes	分页读取管理范围（listScopes）	认证：AdminJwt；成功：200；访问：总管理员；必需头：依认证入口；无额外业务必需头
POST /api/v1/admin/management-scopes	原子新增范围与任命（createScope）	认证：AdminJwt；成功：201；访问：总管理员；必需头：Idempotency-Key
POST /api/v1/admin/management-scope-previews	预览新增范围和任命（scopeCreatePreview）	认证：AdminJwt；成功：200；访问：总管理员；必需头：依认证入口；无额外业务必需头
GET /api/v1/admin/management-scopes/{scopeId}	管理范围详情（getScope）	认证：AdminJwt；成功：200；访问：总管理员；必需头：依认证入口；无额外业务必需头
PUT /api/v1/admin/management-scopes/{scopeId}	原子更新范围及任命（replaceScope）	认证：AdminJwt；成功：200；访问：总管理员；必需头：Idempotency-Key
GET /api/v1/admin/management-scopes/{scopeId}/appointments	分页读取任命及历史（listScopeAppointments）	认证：AdminJwt；成功：200；访问：总管理员；必需头：依认证入口；无额外业务必需头
POST /api/v1/admin/management-scopes/{scopeId}/previews	预览范围与名单替换（scopeEditPreview）	认证：AdminJwt；成功：200；访问：总管理员；必需头：依认证入口；无额外业务必需头

A.10. 审计

方法与路径	操作	认证、响应及必需业务头
GET /api/v1/admin/audit-events	分页筛选授权审计（listAudit）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头
GET /api/v1/admin/audit-events/{auditEventId}	读取审计差异详情（getAudit）	认证：AdminJwt；成功：200；访问：范围；必需头：依认证入口；无额外业务必需头

A.11. 权限调用

方法与路径	操作	认证、响应及必需业务头
POST /api/v1/integration/authorization-queries	查询员工当前有效功能权限（authorizationQuery）	认证：BusinessJwt；成功：200；访问：业务系统；必需头：依认证入口；无额外业务必需头
POST /api/v1/integration/permission-checks	检查员工指定功能权限（permissionCheck）	认证：BusinessJwt；成功：200；访问：业务系统；必需头：依认证入口；无额外业务必需头

A.12. OA结果

方法与路径	操作	认证、响应及必需业务头
POST /api/v1/oa/final-results	接收可信OA最终结果（receiveOaResult）	认证：OaJwt；成功：202/200；访问：OA；必需头：依认证入口；无额外业务必需头

附录 B：数据流、用例、表与模块追踪摘要

处理/用例	主要存储与表组	主要模块/责任
P1 / UC-07、09	D1账号/会话/范围，D2任职，D6申请影响，D7审计	后台身份、管理范围、资格失效与安全读取；A
P2 / UC-01	D3系统/目录/权限，D4/D5引用，D7审计	系统与权限目录、影响预览；B
P3 / UC-02、03、04一般撤销	D4角色草稿，D5来源基线，D6草稿/固定申请及OA关联	变更申请模块编排，调用角色、授权来源、影响预览及OA投递能力；C协调B/D
P4 / UC-10、UC-04离岗	D2组织任职，D5来源/授权，D8导入；D1/D6/D7联动	组织任职、授权来源、人员导入与生命周期处理；D，后台资格联动A
P5 / UC-11	D6审批/执行；D4配置；D5实际授权；D7审计	OA结果与自动执行模块，调用角色配置及授权写入接口；C协调B/D
P6 / UC-05、06	D2、D3、D4、D5同快照读取；D1可信服务身份	有效权限计算与操作校验模块；B
P7 / UC-08	D7审计历史、D6申请关联；D1/D2当前资格	审计查询模块；C

各业务模块共同使用公共基座的事务、幂等和审计追加能力。